

AegisFraud Intelligence Analytics Platform

System Architecture, Security Specification, AI Chatbot & Impact Metrics

Live Deployable URL: <https://aegisfraud-dashboard.onrender.com>
Primary Tech Stack: Python (Flask), Pandas, MySQL (Cloud), HTML5/CSS3, Bootstrap 5, Plotly.js
Cognitive AI Assistant: Google Gemini 3.6 Flash via Google GenAI Client SDK
Document Type: Comprehensive Technical Specification & Deliverable Report

1. System Architecture & Component Interaction

The platform is engineered with an asynchronous, decoupled 3-tier architecture separating the client presentation, REST API application gateway, cognitive AI tools, and transactional database tier.

Architectural Tier	Component & Technology	Operational Functionality
Client Presentation	HTML5, CSS3, Vanilla JS, Bootstrap 5, Plotly.js	Dark theme Single Page Application (SPA). Asynchronous fetch calls populate 13 charts, 7 live KPIs, and the phone-ratio chatbot drawer without page reloads.
API Application Gateway	Python Flask, Gunicorn WSGI, database.py	Hosts core REST endpoints (/api/kpis, /api/charts, /api/sql/run, /api/chat). Enforces AST query filtering, execution timers, and state management.
Cognitive Assistant	Google Gemini 3.6 Flash, chatbot_engine.py, ai_tools.py	Domain-specialized assistant receiving controlled JSON context from analytics.py. Prohibited from executing raw database operations.
Data Storage & Query Engine	Cloud MySQL 8.0, mysql-connector-python	Holds 4 normalized tables (200,000 transactions, 6,146 cards, 2,000 users, 44,459 merchants). Executes complex analytical window queries in sub-200ms.

2. Core Dashboard Features & Capabilities

A. Executive Telemetry KPI Bar: Aggregated live metrics calculated over 200,000 transactions:

- **Monitored Entities:** 2,000 unique cardholders across 6,146 active credit/debit cards.
- **Gross Volume:** 200,000 processed transactions representing \$10,674,909.60 in total volume.
- **Fraud Incidents:** 29,757 confirmed breach records (14.88% incident frequency).
- **Net Financial Exposure:** \$3,231,338.63 in monetary fraud losses (30.27% of portfolio value).
- **Ticket Size Gap:** Average fraud ticket of \$108.59 vs. normal median ticket of \$45-\$55.

B. The 4 Dedicated Navigation Panels:

- **Executive Overview:** High-level portfolio briefing banner, 4-pillar threat matrix (CNP Risk, Velocity Clusters, Dark Web Leaks, FICO Skew), and 4-stage pipeline lifecycle (Ingestion → Scoring → Triaging → Enforcement).
- **Executive Insights:** High-priority risk signals, annual trend trajectory, identified governance and regulatory gaps, and prioritized security remediation roadmap.
- **Graph Insights (5-4-4 Division Layout):** 13 curated Plotly visualizations across Macro Trends (5 charts: overall share, channels, ticket bands, annual rate, volume over time), Entity Risk (4 charts: 24/7 day-hour heatmap, card brands, debit vs credit, FICO bands), and Geospatial Risk (4 charts: U.S. choropleth map 0-1,000 scale, loss vs volume, box plot

dispersion, ticket size donut).

- **SQL Query Explorer ('The Big Shot')**: Enterprise workbench with 6 business modules (Core Rules, Multi-Factor Scoring, Business Insights, Card Security, Merchant Network, Customer Demographics). Includes live execution (<200ms), runtime metrics, formatted table display, and single-click CSV export.

3. Security Architecture & Multi-Layer Guardrails

The platform applies a defense-in-depth security model across HTTP routing, AST token parsing, and AI interaction boundaries to prevent unauthorized mutations or data exfiltration:

Security Layer	Implementation Mechanism	Threat Mitigated
Multi-Statement Blocking	Queries are stripped of comments (-- and /* */) and split by semicolons. If statements > 1, query is blocked with HTTP 403.	Multi-query injection attacks and piggybacked commands (e.g. SELECT * ...; DROP TABLE).
AST Read-Only Enforcement	Normalized queries must strictly begin with SELECT or WITH. 18 forbidden keywords (DROP, ALTER, TRUNCATE, INSERT, DELETE, GRANT, etc.) are rejected.	Unauthorized schema mutations, database tampering, privilege escalation, and data destruction.
Credential Sandboxing	Database credentials loaded strictly via environment variables. Public endpoint /api/db/config disabled (HTTP 403).	Configuration hijacking and credential exposure in public client environments.
AI Execution Sandboxing	Gemini AI has zero direct database connectivity. Receives strictly vetted, read-only analytics JSON from ai_tools.py.	Prompt injection attacks attempting to execute arbitrary SQL or exfiltrate private schema data.

4. Virtual Avatar Chatbot (Google Gemini 3.6 Flash)

Integrated as a floating bottom-right drawer (380px × 580px) powered by Google's latest Gemini 3.6 Flash model with controlled grounding context:

- **Grounding via ai_tools.py**: The bot receives real-time JSON context for the specific question topic (KPIs, payment channels, FICO categories, or heatmaps). It is strictly instructed never to hallucinate or guess numbers.
- **SQL Query Translation & Result Explanation**: Accepts the user's SQL Explorer query and output table, explaining table joins, aggregations, window functions, and business risk implications in plain executive English.
- **One-Click Prompt Chips**: Quick buttons for rapid inquiries (Overall KPIs, Channel Risk, Risk Engine Scoring, High-Risk Merchants).
- **Enterprise Formatting**: Formats responses using clean markdown bolding, lists, structured comparative tables, and strategic risk remediation guidance.

5. Summary of Benchmark & Business Impact Metrics

All metrics below are derived from empirical code execution against the 200,000 credit card transaction portfolio:

Category	Benchmark Metric	Business Significance & Value
ETL Ingestion Time	7.0 seconds	Full chunked load (5,000-row batches) of 200K records from raw CSV into normalized MySQL schema via Pandas and mysql-connector-python.

Statistical Precision	45.3%	Combined Z-Score + IQR statistical outlier detection precision against ground-truth fraud labels on skewed ticket amounts.
Query Latency	< 200 ms	Sub-second query execution time on analytical window queries and aggregations across 200K transactions in MySQL.
Channel Loss Dominance	68.4%	Over two-thirds of total monetary fraud losses stem from Online (Card-Not-Present) channels, driving 3DS 2.0 biometric enforcement.
Risk Engine Separation	8.7x	The 4-factor scoring algorithm achieves 8.7-fold higher fraud density in the High-Risk tier vs. Low-Risk, slashing false positives.
Dark Web Multiplier	3.4x	Credentials leaked on dark web repositories exhibit a 3.4-fold spike in unauthorized charge activity, justifying instant token revocation.
Temporal Fraud Window	01:00 - 05:00 AM	Temporal heatmap analysis isolates early morning hours as the primary multi-swipe surge window, establishing automated off-hour velocity rules.